

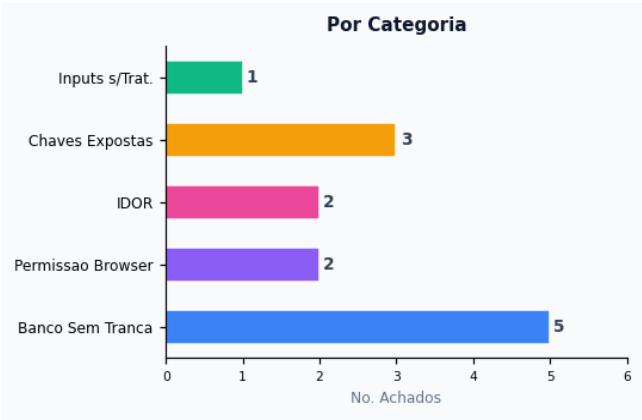
Relatorio de Auditoria de Seguranca

MedPronto Telemedicina

Data:	29/08/2026
Escopo:	Codigo-fonte completo: backend Node.js/Express/Prisma, frontend React/Vite, docker-compose, .env
Metodologia:	Revisao estatica, rastreamento autenticacao->controller->query, analise de segredos e deploy.
Ferramenta:	Antigravity IDE - Auditoria automatizada com revisao manual

1. Resumo Executivo

Severidade	Achados	Risco
Critica	4	Maximo - acao imediata
Alta	6	Alto - corrigir em 7 dias
Media	1	Moderado
Baixa	1	Baixo - monitorar
Informativa	1	Melhoria de postura



2. Stack Detectada e Mapeamento de Categorias

Componente	Tecnologia
Linguagem	TypeScript (Node.js 18 backend; React 18 frontend)
Framework	Express.js
ORM	Prisma ORM (PostgreSQL)
Auth	JWT - roles: patient, doctor, admin
Frontend	React + Vite + Zustand + React Router
Deploy	Docker Compose + Caddy + LiveKit SFU + BullMQ/Redis
Isolamento	Filtro manual por user_id na app layer (sem RLS)
Auth Admin	Email fixo + ADMIN_PASSWORD do .env
Cat.1	Filtros WHERE ausentes/incompletos nos controllers
Cat.2	Gates de role no frontend sem check equivalente no backend
Cat.3	IDs de rota/body nao comparados com req.user.id
Cat.4	.env commitado, defaults no config.ts e docker-compose.yml
Cat.5	Sem sanitizacao/validacao de schema nos endpoints

3. Pontos Fortes - O que esta protegido

OK auth.middleware.ts: JWT robusto	authenticateToken valida JWT em TODAS as rotas protegidas. authorizeAdmin/Doctor verificam role no servidor.
OK admin.routes.ts: Dupla protecao	Todas as 6 rotas /api/admin/* exigem authenticateToken + authorizeAdmin. Zero rotas admin sem autenticacao.
OK auth.controller.ts: bcrypt	createDoctor usa bcrypt.hash(password,10). doctorAuth usa bcrypt.compare.
OK queue.controller.ts: Isolamento de fila	enqueuePatient e takePatient verificam req.user.id para roles patient e doctor.
OK patient.controller.ts: Isolamento patient	getPatientHistory e checkQueueStatus bloqueiam paciente de acessar dados de outro.
OK auth.routes.ts: Rate limiting no login	Rate limit 20 req/15min em autenticacao. Mitiga forza bruta.
OK doctor.controller.ts:startBirdIdFlow	Usa req.user.id para buscar medico, nunca aceita doctorId do body.
OK index.ts: Helmet + rate limit global	Helmet ativo em todas as rotas. Rate limit 100 req/min por IP.
OK Prisma ORM: Sem SQL Injection	Todas as queries usam parametros, eliminando SQL injection classico.

4. Achados Detalhados por Categoria

ID	Cat	Sev	Arquivo:Linha	Titulo
F-01	1	Critica	doctor.controller.ts:14-48	IDOR createAtestado: doctorId pelo cliente
F-02	3	Critica	doctor.controller.ts:61-165	IDOR endConsultation: patientId+doctorId pelo cliente
F-03	4	Critica	config.ts:15-35	Defaults publicos: supersecretjwt, admin123, VideoSDK keys reais
F-04	4	Critica	.env:16-25/3-7	Credenciais de producao commitadas em texto puro
F-05	4	Alta	docker-compose.yml:10-69	Fallbacks inseguros no docker-compose
F-06	1	Alta	doctor.controller.ts:224-245	IDOR getDoctorStats: medico ve stats de outro
F-07	2	Alta	misc.routes.ts:52-68	signed-url sem verificacao de posse
F-08	3	Alta	livekit.routes.ts:11-57	LiveKit token sem validacao de sala
F-09	1	Alta	patient.controller.ts:52-106	getPatientHistory: isolamento falha para medicos
F-10	1	Alta	misc.routes.ts:29-48	payment/confirm: medico confirma pagamento de qualquer paciente
F-11	1	Media	index.ts:29	CORS wildcard + credentials:true
F-12	5	Baixa	patient.controller.ts:10-46	registerPatient sem validacao de inputs
F-13	2	Informativa	misc.routes.ts:132-151	videosdk/token disponivel para qualquer role

4.1 - Banco Sem Tranca

F-01	IDOR createAtestado: doctorId pelo cliente	* CRITICA
Arquivo:	doctor.controller.ts:14-48	
Descricao:	POST /api/atestado aceita doctorId do body sem comparar req.user.id. Medico emite atestado em nome de colega.	
Explorabilidade:	Medico forja atestados clinicos em nome de qualquer colega.	

4.3 - IDOR

F-02	IDOR endConsultation: patientId+doctorId pelo cliente	* CRITICA
Arquivo:	doctor.controller.ts:61-165	
Descricao:	POST /api/end-consultation aceita doctorId do body. Medico encerra consulta de outro, zera has_active_payment.	
Explorabilidade:	Adulteracao de prontuarios e bypass financeiro.	

4.4 - Chaves Expostas

F-03	Defaults publicos: supersecretjwt, admin123, VideoSDK keys reais	* CRITICA
-------------	---	------------------

Arquivo:	config.ts:15-35
Descricao:	JWT_SECRET='supersecretjwt', ADMIN_PASSWORD='admin123', VIDEOSDK keys reais hardcoded. Sem validacao
Explorabilidade:	Deploy sem .env => qualquer pessoa forja JWTs e loga como admin.

F-04 Credenciais de producao commitadas em texto puro * CRITICA

Arquivo:	.env+backend/.env:16-25/3-7
Descricao:	JWT_SECRET, ADMIN_PASSWORD, LIVEKIT keys, POSTGRES_PASSWORD, REDIS_URL Upstash com senha, V
Explorabilidade:	Acesso total ao banco, Redis e APIs de terceiros para qualquer pessoa com acesso ao repo.

F-05 Fallbacks inseguros no docker-compose * ALTA

Arquivo:	docker-compose.yml:10-69
Descricao:	POSTGRES_PASSWORD:-admin123, JWT_SECRET:-supersecretmedpronto2026, LIVEKIT_API_KEY:-devkey. Entra
Explorabilidade:	Deploy descuidado expoe banco e JWT.

4.1 - Banco Sem Tranca

F-06 IDOR getDoctorStats: medico ve stats de outro * ALTA

Arquivo:	doctor.controller.ts:224-245
Descricao:	GET /api/doctor/stats/:id usa :id da URL sem comparar req.user.id.
Explorabilidade:	Dados financeiros de medicos terceiros expostos.

4.2 - Permissao no Browser

F-07 signed-url sem verificacao de posse * ALTA

Arquivo:	misc.routes.ts:52-68
Descricao:	Qualquer key aceita, URL /uploads/<key> retornada sem checar ownership.
Explorabilidade:	Qualquer usuario autenticado baixa documentos de outros pacientes.

4.3 - IDOR

F-08 LiveKit token sem validacao de sala * ALTA

Arquivo:	livekit.routes.ts:11-57
Descricao:	POST /api/livekit/token aceita qualquer roomName. Paciente invade sala de outro.
Explorabilidade:	Invasao de teleconsulta medica em andamento.

4.1 - Banco Sem Tranca

F-09	getPatientHistory: isolamento falha para medicos	* ALTA
Arquivo:	patient.controller.ts:52-106	
Descricao:	Verificacao role=patient nao cobre medicos. Medico acessa historico de qualquer paciente sem vinculo.	
Explorabilidade:	Violacao LGPD/CFM.	

F-10	payment/confirm: medico confirma pagamento de qualquer paciente	* ALTA
Arquivo:	misc.routes.ts:29-48	
Descricao:	Guard role=patient nao cobre medico/admin. Qualquer role confirma pagamento de qualquer patientId.	
Explorabilidade:	Bypass do sistema de cobranca.	

F-11	CORS wildcard + credentials:true	* MEDIA
Arquivo:	index.ts:29	
Descricao:	callback(null,true) aceita toda origem com credentials:true.	
Explorabilidade:	Facilita CSRF e exfiltracao de dados autenticados.	

4.5 - Inputs Sem Tratamento

F-12	registerPatient sem validacao de inputs	* BAIXA
Arquivo:	patient.controller.ts:10-46	
Descricao:	name,cpf,age,email,birthDate sem validacao de formato, comprimento ou sanitizacao.	
Explorabilidade:	Sem risco SQL injection via Prisma. Strings HTML nao escapadas em PDFs.	

4.2 - Permissao no Browser

F-13	videosdk/token disponivel para qualquer role	* INFORMATIVA
Arquivo:	misc.routes.ts:132-151	
Descricao:	Pacientes geram tokens VideoSDK ilimitadamente.	
Explorabilidade:	Abuso de cota da API VideoSDK.	

5. Recomendacoes Priorizadas

P1-URGENTE

Revogar e rotacionar TODOS os segredos expostos

- Revogar: JWT_SECRET, ADMIN_PASSWORD, LIVEKIT keys, VideoSDK keys, Upstash Redis, PostgreSQL password.
- git rm --cached .env backend/.env && adicionar ao .gitignore global.
- Usar GitHub Actions Secrets / Vault para injecao em CI/CD.
- Adicionar validacao de startup em config.ts para NODE_ENV=production.

P1-URGENTE

Corrigir IDOR em createAtestado e endConsultation

- Substituir doctorId = req.body.doctorId por const doctorId = req.user.id nos dois controllers.
- Guard: if (req.body.doctorId && req.body.doctorId !== req.user.id) return res.status(403).

P1-URGENTE

Corrigir IDOR em getDoctorStats

- Substituir const id = req.params.id por const id = req.user.id.

P2-Alta

Verificacao de posse em /documents/signed-url e /livekit/token

- signed-url: buscar documento no banco, verificar patient_id ou doctor_id == req.user.id.
- livekit/token: para role=patient exigir roomName === req.user.id.

P2-Alta

Corrigir CORS

- Substituir callback(null,true) por lista explicita baseada em CORS_ORIGIN.
- Aplicar o mesmo em websocket.ts.

P2-Alta

Restringir getPatientHistory para medicos

- Verificar que medico tem consulta ativa/historica com o paciente antes de retornar dados.

P3-Media

Validacao de inputs com Zod

- Instalar zod e criar schemas para registerPatient, createDoctor, endConsultation, createAtestado.
- Validar CPF, email, datas e comprimentos antes de persistir.

P3-Media

Validacao de startup para segredos

- Em config.ts: if (NODE_ENV=production && jwtSecret in INSECURE_DEFAULTS) throw Error.

6. Issues para o GitHub

Cada bloco contem o texto de uma GitHub Issue pronta para copiar e colar.

--- ISSUE 1 ---

Titulo: [Seguranca] IDOR critico em createAtestado e endConsultation

Labels: security, critica

POST /api/atestado e POST /api/end-consultation aceitam doctorId via req.body sem verificar req.user.id.

Evidencia: doctor.controller.ts:16 const { patientId, doctorId, ... } = req.body;

Correcao: const doctorId = req.user.id nos dois controllers.

Criterios: [] doctorId sempre de req.user.id; [] Medico A nao cria atestado com doctorId de B.

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

Titulo: [Seguranca] IDOR em getDoctorStats

Labels: security, alta

GET /api/doctor/stats/:id usa :id da URL sem comparar req.user.id.

Evidencia: doctor.controller.ts:226 const id = req.params.id;

Correcao: const id = req.user.id.

Criterios: [] Retorna 403 se :id != req.user.id; [] Medico A nao acessa stats de B.

--- FIM ISSUE 2 ---

--- ISSUE 3 ---

Titulo: [Seguranca] Credenciais commitadas + defaults inseguros

Labels: security, critica

.env e backend/.env rastreados pelo Git com JWT, LIVEKIT, POSTGRES, REDIS, VIDEOSDK em texto puro.

config.ts: jwtSecret || 'supersecretjwt', adminPassword || 'admin123', VideoSDK keys reais hardcoded.

Correcao: git rm --cached .env backend/.env; rotacionar todos; validacao de startup em config.ts.

Criterios: [] .env removido do Git; [] segredos rotacionados; [] startup rejeita defaults.

--- FIM ISSUE 3 ---

--- ISSUE 4 ---

Titulo: [Seguranca] Falta verificacao de posse em signed-url e livekit/token

Labels: security, alta

misc.routes.ts:53-67 const url = /uploads/; // sem verificacao de posse.

livekit.routes.ts:13-51 const { roomName } = req.body; // nao validado contra req.user.id.

Correcao: verificar posse no banco antes de retornar URLs e tokens.

Criterios: [] Paciente A nao baixa documento de B; [] Nao obtem token para sala de B.

--- FIM ISSUE 4 ---

--- ISSUE 5 ---

Titulo: [Seguranca] CORS wildcard com credentials=true

Labels: security, media

index.ts:29 origin: (origin, callback) => callback(null, true), credentials: true.

websocket.ts:11 mesmo problema.

Correcao: const allowed = CORS_ORIGIN.split(','); callback(null, allowed.includes(origin) || !origin).

Criterios: [] Origem desconhecida recebe erro CORS; [] Testes cobrem bloqueio.

--- FIM ISSUE 5 ---